

A Trusted Authorisation Framework for Multi-Party Patient Consent in Healthcare Data Sharing

Design, HALAH prototype and evidence for RO1–RO4, with the plan for RO5–RO6

Yasir Dhaifallah O Alyoubi

Student ID 24724078

Principal Supervisor: Professor Farookh Hussain

Co-Supervisor: Dr Firas Al-Doghman

September 2026



 current stage  next stage

Five parts of this presentation



Background and literature

Chapters 1–2: context, problem, key requirements and systematic review



Research design

Chapters 3–4: research gap, main question, SRQ1–SRQ6 and RO1–RO6



Architecture and solution

Chapters 5–6: MVC architecture; workflow and algorithm for each RO



HALAH prototype and evidence

Chapter 7: four subsystems, code mapping, tests and on-chain evidence



Progress and research plan

Chapters 8–10: progress per RO, publications and next-stage work (RO5–RO6)



A

PART A • CHAPTERS 1-2

Background and literature

Consent is recorded, not evaluated; none of the 33 studies combines all five requirements in one decision

Who shares healthcare data, and under which rules

Sections 1.1, 2.2, 2.4.1 and 5.1: authorisation as a distributed governance problem in the Australian setting

Several independent parties take part in healthcare data sharing, and no single participant may hold enough authority to decide access alone.



Patients

Initiate consent and should have greater control over how their data is accessed, shared and reused



Guardians, authorised parties

Hold part of the authority in paediatric, aged-care and shared-guardianship settings



Healthcare professionals

A valid credential shows a registered practitioner, not authority for this patient, purpose and data



Institutions and auditors

Institutions may hold part of the authority; auditors inspect authorisation evidence and audit history



Privacy Act 1988 and APPs

Sensitive information: collect with consent (APP 3); use for primary or directly related purpose (APP 6)



My Health Records and HI Acts

My Health Records Act 2012: consumers control provider access; Healthcare Identifiers Act 2010: IHI, HPI-I, HPI-O

The core problem

Section 1.2: consent often remains a passive artefact, separate from the access decision



**Identity is not authority;
recorded consent is not
evaluated consent**

1

Identity without authority

An immutable record does not prove participants were legitimate; authentication does not prove authority

2

One party acting alone

Guardians, clinicians or institutions may also need to approve; one participant should not decide alone

3

Requests beyond scope

A verified, approved professional may still request data outside the purpose or scope the patient authorised

Research scope and progression

Table 1.1: four objectives in the current stage, two in the next stage

Current stage (CA2)	Next stage (CA3)
RO1 Trust-Centric Consent Model	RO5 Temporal and Lifecycle Trust Validity periods, expiration, revocation and controlled consent-state transitions
RO2 Decentralised Identity and Authority Trust	RO6 Formal Security Assurance and Empirical Validation Formal security and authorisation properties; empirical evaluation with negative and adversarial scenarios
RO3 Trustworthy Multi-Party Authorisation	
RO4 Policy- and Context-Aware Access Control	

CA2 lays the foundations of trustworthy multi-party authorisation; CA3 extends it over time and validates it formally and empirically

SLR method: PRISMA 2020 in four steps

Section 2.3: peer-reviewed studies, 2022–2026, on consent, identity, authorisation and access control

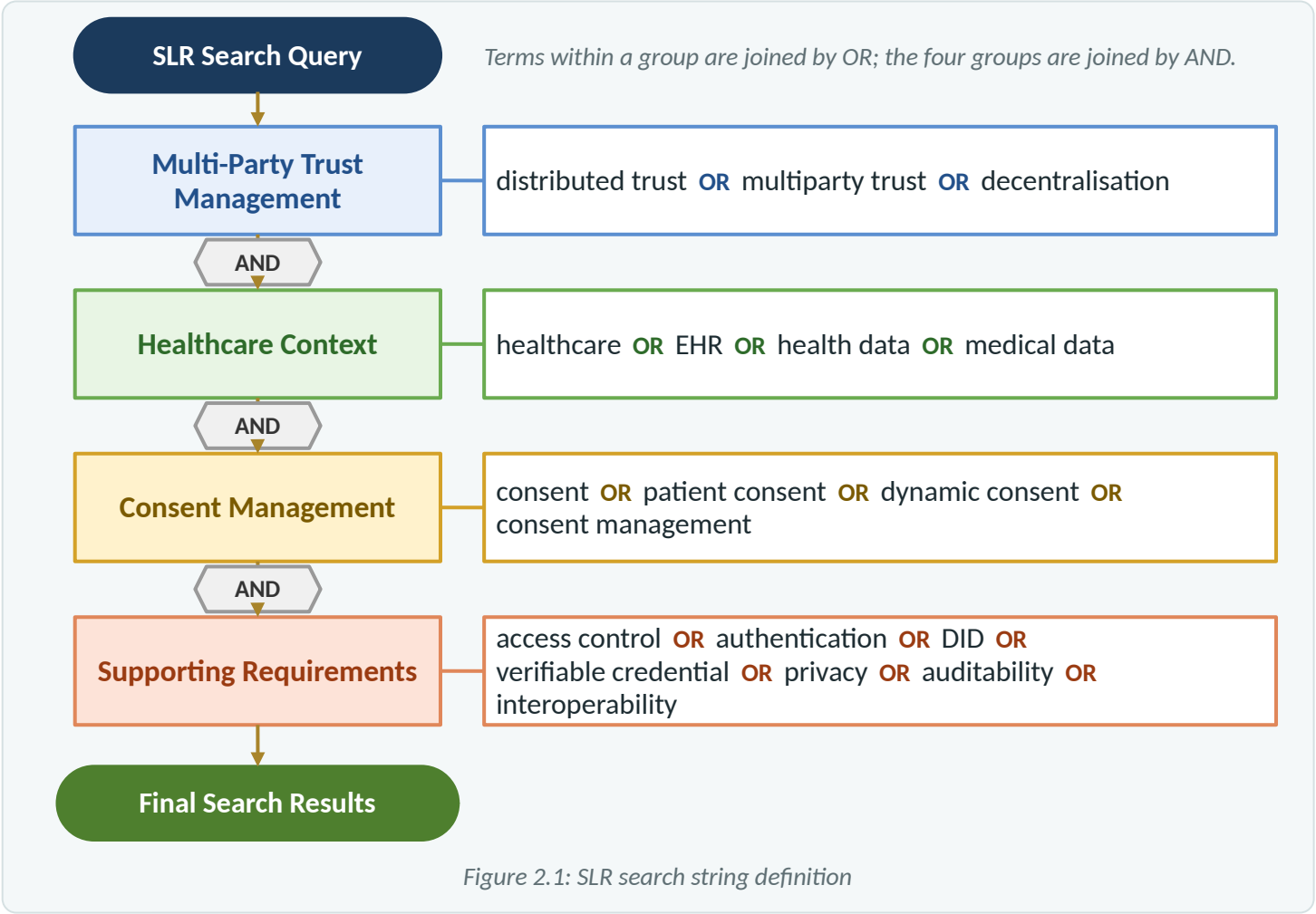
- 1

Literature search
Seven databases, 2022–2026, Boolean search string (Figure 2.1); searched 15 August 2026
- 2

Inclusion/exclusion
Six inclusion and six exclusion criteria set before screening (peer-reviewed, full text, English)
- 3

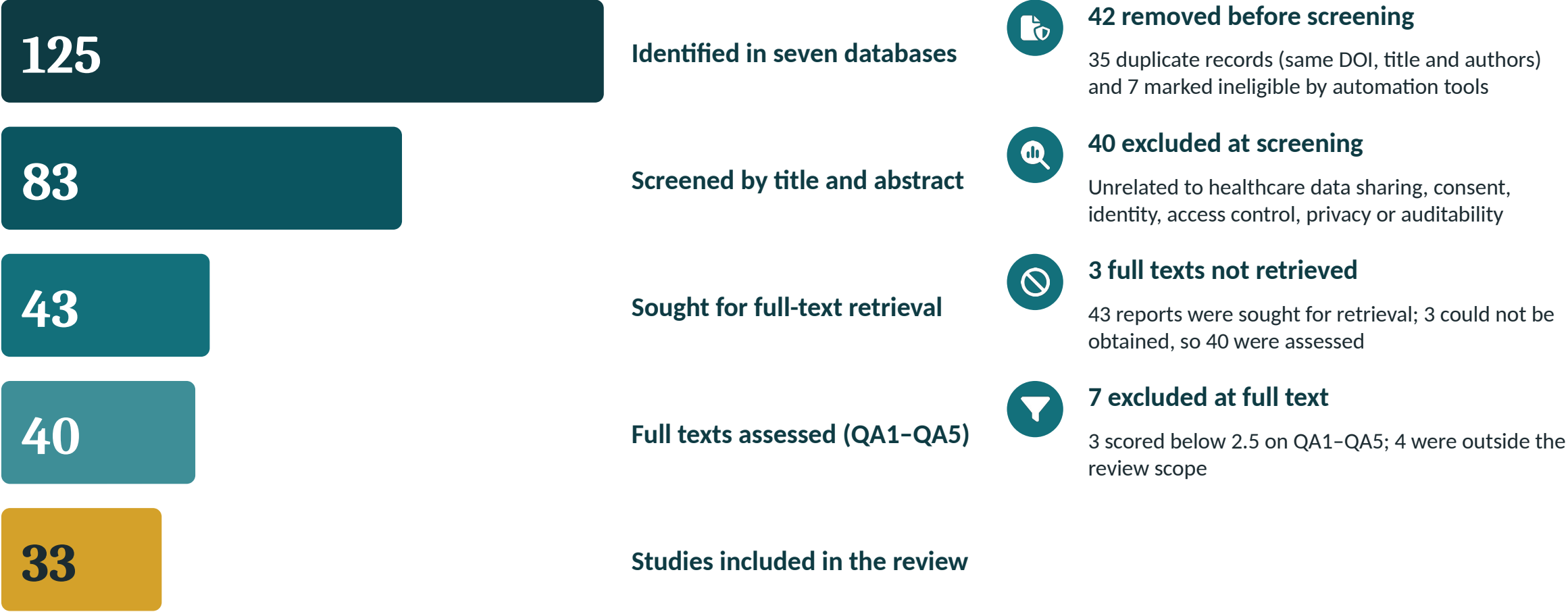
Screening and quality
Title-abstract, then full-text screening; each study scored 1, 0.5 or 0 on QA1–QA5; below 2.5 of 5 excluded
- 4

Extract and categorise
Predefined extraction framework; 33 studies coded S1–S33 and placed in six categories (Table 2.3)



PRISMA selection: from 125 records to 33 studies

Figure 2.2 and Table 2.2: identification, screening, eligibility and inclusion



Five requirements for a trustworthy decision

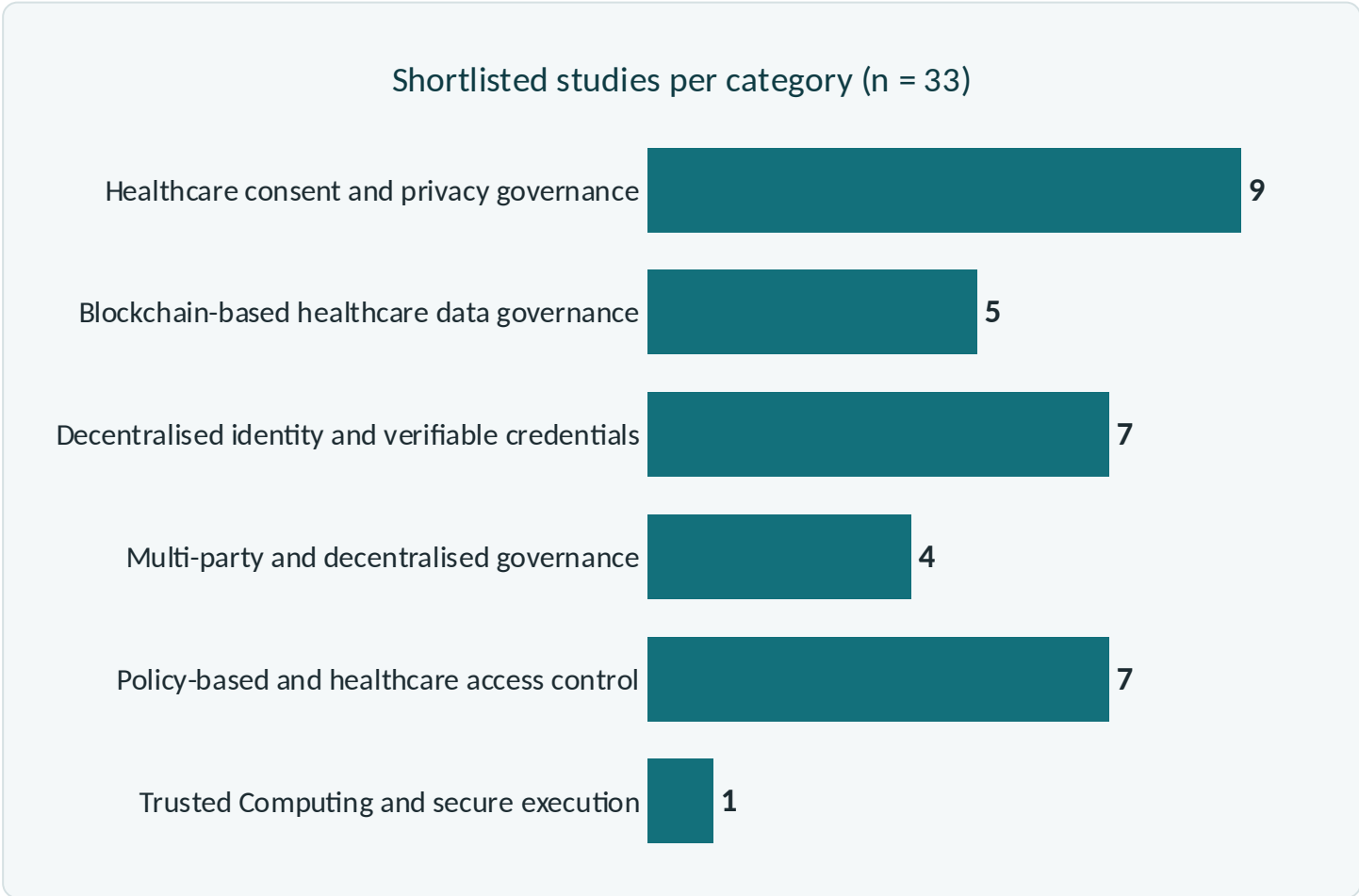
Section 2.2: derived from the Chapter 1 problem and the Australian regulatory setting

The framework must meet five requirements for a trustworthy data-access decision; each of the 33 studies is assessed against them.



33 studies in six categories

Table 2.3: categorisation of the shortlisted studies S1–S33 (Step 4, Section 2.3.6)



Consent governance leads

Nine studies stress autonomy and informed consent, but consent remains a record, not an evaluated object



Security layers stay separate

Identity (7), access control (7) and blockchain (5) each secure one layer; no single mechanism makes the access decision trustworthy



Few multi-party studies

Four multi-party studies and one Trusted Computing study; approval as a consent condition gets less attention

No study covers more than three requirements

Tables 2.4–2.9: number of studies in each category that address each requirement

Category	Studies	Req 1	Req 2	Req 3	Req 4	Req 5
Healthcare consent and privacy governance	9	7	1	0	1	5
Blockchain-based healthcare data governance	5	1	0	0	4	5
Decentralised identity and verifiable credentials	7	0	7	1	2	1
Multi-party and decentralised governance	4	1	2	2	3	2
Policy-based and healthcare access control	7	0	1	0	7	5
Trusted Computing and secure execution	1	0	0	0	0	0
All studies	33	9	11	3	17	18

Number = studies addressing the requirement (✓ in Tables 2.4–2.9); shade = share of the category's studies.

Req 4 (17 studies) and Req 5 (18) are addressed most often, Req 3 by only three. No study addresses more than three of the five; S7, S22 and S24 reach three.



Coverage follows category

Req 1 comes mostly from consent governance (7 of 9) and Req 2 from identity studies (7 of 11)



Req 3 is the weakest

Only S15, S23 and S25 address it, and none attaches an approval threshold to the patient's consent

Five gaps, one per requirement

Section 2.5: research gaps in the existing studies from the requirement perspective

Req 1	Consent recorded, not evaluated	Nine studies record, encrypt, execute or legally define consent; none carries the conditions to evaluate a later request
Req 2	Identity verified, authority not	Eleven studies establish who a participant is; none verifies the authority a consent requires as a separate condition
Req 3	No threshold on the consent	S15, S23 and S25 offer multi-party mechanisms, but no threshold of verified approvals is attached to the consent
Req 4	Policy not bound to consent scope	Policy follows roles, attributes or risk, not the consented purpose and scope, so approved requesters can exceed it
Req 5	Consent lifecycle not checked	Expiry, revocation and state not evaluated at request time; evidence records transactions, not trust conditions

The gaps map in order to RO1–RO5 (Req 1 to Req 5); RO6 provides formal and empirical validation of the resulting decisions.

Each stream addresses one layer

Table 2.10 (condensed): comparison of the existing research streams and the proposed framework

Research stream	Main contribution	Limitation for authorisation
Healthcare consent and privacy governance	Patient autonomy, informed consent and controlled data sharing	Consent treated as permission, not an evaluable authorisation object
Blockchain-based healthcare data governance	Tamper-resistant records, distributed auditability and transparency	Immutable records do not establish legitimacy, authority or compliance
Decentralised identity and verifiable credentials	Self-controlled identity, verifiable attributes and authentication	Identity and credential validity alone do not authorise access
Multi-party and decentralised governance	Collaborative participation and distributed verification or governance	Limited integration between collective approval thresholds, consent and access decisions
Policy-based and healthcare access control	Fine-grained restriction by attributes, risk, context and constraints	Policy separated from decentralised identity and multi-party consent
Trusted Computing and secure execution	Hardware-supported isolation, execution integrity and attestation	Secure execution does not decide if authorisation conditions suffice
Proposed framework	Integrated evaluation: consent, identity, authority, approval, policy	Still to add: lifecycle trust, formal assurance, empirical validation



B

PART B • CHAPTERS 3-4

Research design

The Chapter 2 gap becomes one main question, six SRQs and six ROs, staged across CA2 and CA3

The missing piece is an integrated trust model

Research gap (Section 3.1) and main research question (Section 3.2)



How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority and policy constraints?

1

Fragmented mechanisms

Blockchain consent, DIDs, VCs, policy control and multi-party approval are studied separately, not as one model.

2

Consent kept as a record

Access may rest mainly on a stored record and an authenticated requester, not proven authority, approvals or scope.

3

No single source of trust

Immutability, identity or approval alone cannot make access trustworthy; trust emerges from a verifiable process.

Six questions, six objectives, two stages

SRQ1–SRQ6 map one-to-one onto RO1–RO6 (Tables 4.1–4.2); RO1–RO4 in CA2, RO5–RO6 in CA3

SRQ	Question focus	Objective	Stage
SRQ1	Consent as a trust-aware, evaluable authorisation object	RO1: Trust-Centric Consent Model	Current (CA2)
SRQ2	DIDs and VCs, with identity separated from authority	RO2: Decentralised Identity and Authority Trust	Current (CA2)
SRQ3	Verified parties jointly decide; no unilateral authorisation	RO3: Trustworthy Multi-Party Authorisation	Current (CA2)
SRQ4	Policy, purpose and data-scope constraints in authorisation	RO4: Policy- and Context-Aware Access Control	Current (CA2)
SRQ5	Validity interval, expiry, revocation and state transitions	RO5: Temporal and Lifecycle Trust	Next (CA3)
SRQ6	Formal security properties and empirical validation	RO6: Formal Security Assurance and Empirical Validation	Next (CA3)

Access is a conjunction of trust conditions

Eq. 6 decides access now (CA2); Eq. 24 adds temporal and lifecycle checks in CA3

Consent object (Eq. 7)

$$C = (I, A, P, E)$$

I identity · A authority and authorisation requirements · P policy and data scope · E evidence

Current-stage decision (Eq. 6)

$$\text{Decision}(C, R) = \text{ALLOW} \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R)$$

Next-stage decision (Eq. 24)

$$\text{Decision}(C, R, t) = \text{ALLOW} \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C)$$



**Identity and
authority**

VerifyDID(u) $\wedge$ VerifyVC(u):
DID shows who u is, VC shows
role or authority (Eq. 8)



**Multi-party
authorisation**

Holds only if $|A_v| \geq N$ verified
approvals; $|A_v| < N \Rightarrow \text{DENY}$
(Eqs. 9–10)



**Policy and scope
compliance**

R must meet the consent's
purpose and scope; $S_R \not\subseteq S_C \Rightarrow$
reject (Eqs. 11, 5)



Temporal validity

Next stage: $t_s \leq t \leq t_e$, time t
lies within the consent's
validity interval (Eq. 12)



Lifecycle validity

Next stage: ValidState(C) $\wedge$
ValidTransition(C); not expired,
revoked or invalid (Eq. 15)

Identity is not authorisation (Eq. 1). ALLOW only when every predicate holds; if any one fails, the decision is DENY (Eq. 18).



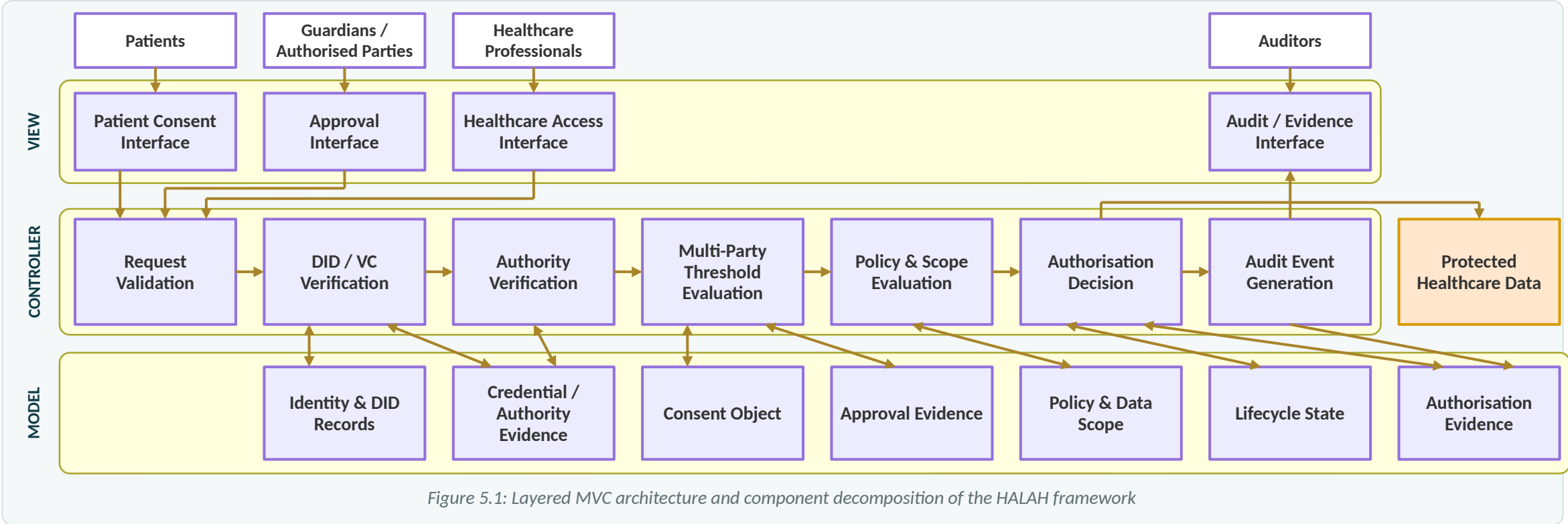
PART C • CHAPTERS 5-6

Architecture and solution

MVC separates security state, interaction and enforcement; a workflow and an algorithm for each of RO1-RO6

Every sensitive decision passes through the Controller

Section 5.1: the View submits claims, the Controller decides, the Model holds security state



View: interaction boundary

Role interfaces for patients, guardians, healthcare professionals and auditors; actions are claims, not decisions



Controller: enforcement

Validates requests; verifies DID, VC and authority; checks threshold and policy; decides; generates audit evidence



Model: security state

DIDs, credentials, consent objects, approvals, policy and scope, evidence, lifecycle; state is not permission

Access requires every trust predicate to hold

Figure 5.3, Table 5.1: the Controller checks V_I , V_A , V_P , V_T , V_L ; any false predicate gives DENY (Eq. 18)

-  **Authority separation**
Identity and authority evidence checked separately; authentication alone does not authorise
-  **Multi-party authorisation integrity**
Threshold on verified approvals; no unilateral access when collective approval is required
-  **Policy-bounded access**
Purpose and requested scope checked against the consent; approvals cannot exceed its scope
-  **Authorisation evidence**
Verification results, approvals, policy outcome and decision recorded for both ALLOW and DENY

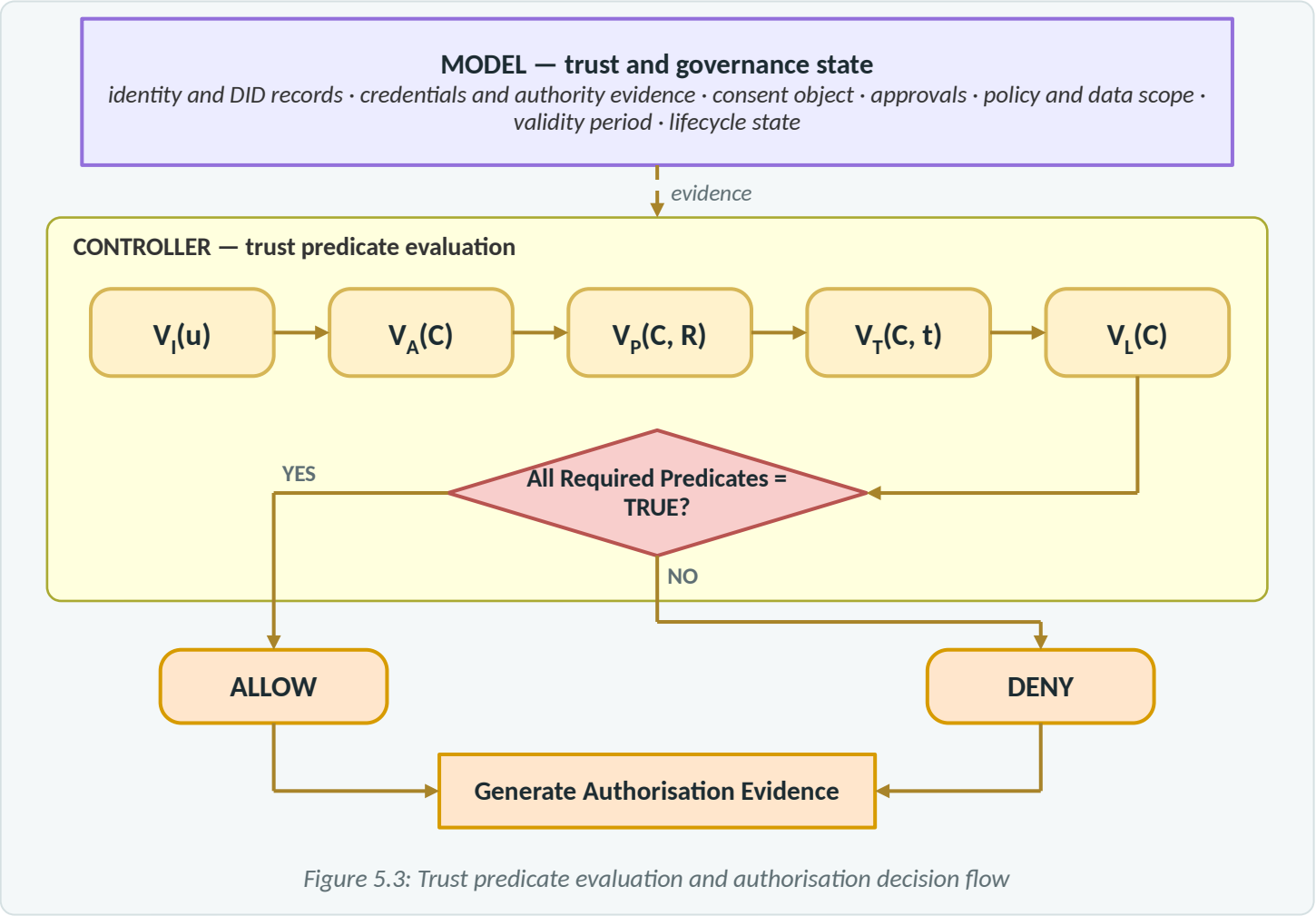


Figure 5.3: Trust predicate evaluation and authorisation decision flow

From consent specification to audited decision

Section 5.2: consent becomes an evaluable authorisation object, checked before data are released

- **Consent specification**
Patient defines purpose, permitted data scope and conditions: the policy context for later requests
- **Identity and authority**
DIDs and VCs establish identity and claimed role or authority; this alone does not grant access
- **Multi-party approval**
Independent approvals collected; unless $|A_v| \geq N$ (Eq. 9), the process ends in DENY
- **Policy, decision and audit**
Purpose and $S_R \subseteq S_C$ checked; $V_I \wedge V_A \wedge V_P$ (Eq. 6) decides; ALLOW and DENY both recorded

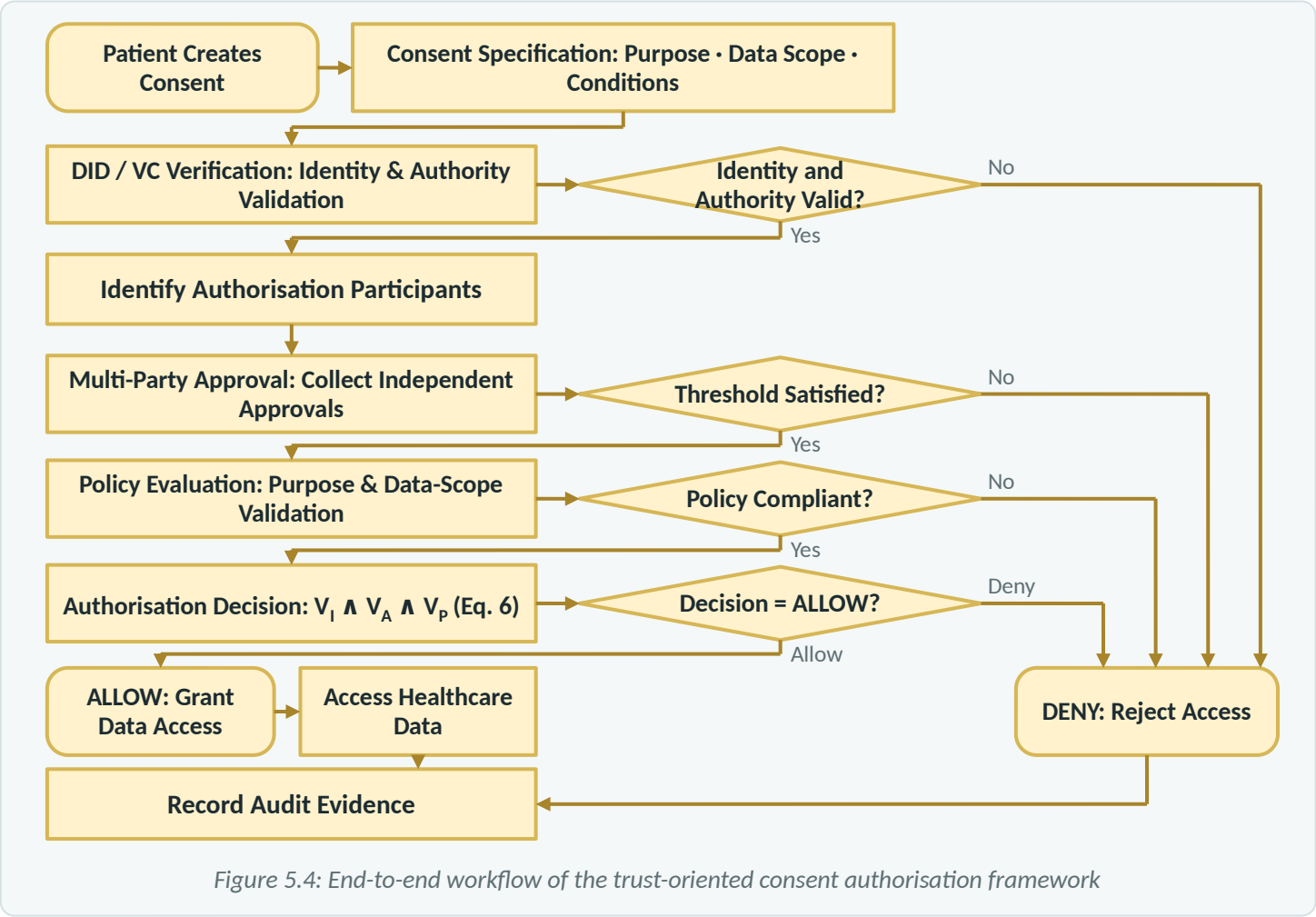


Figure 5.4: End-to-end workflow of the trust-oriented consent authorisation framework

RO1: consent as an evaluable object

Section 6.1 and Algorithm 1: the consent sets the conditions a later request is evaluated against



C = (I, A, P, E)

I = identity, A = authorisation requirements, P = purpose and data-scope policy, E = authorisation evidence



Validate, then construct

Patient, doctor, guardians, purpose, scope S_C and interval T checked; t_e must be later than t_s



Algorithm 1: C or REJECT

Does not grant access directly; assigns id_C , persists C and records creation evidence for audit



Prototype status

Patient, doctor and guardian checks (Steps 1–3) not yet enforced at creation; VC authority checks in CA3; $t_e > t_s$ check (Step 6) implemented

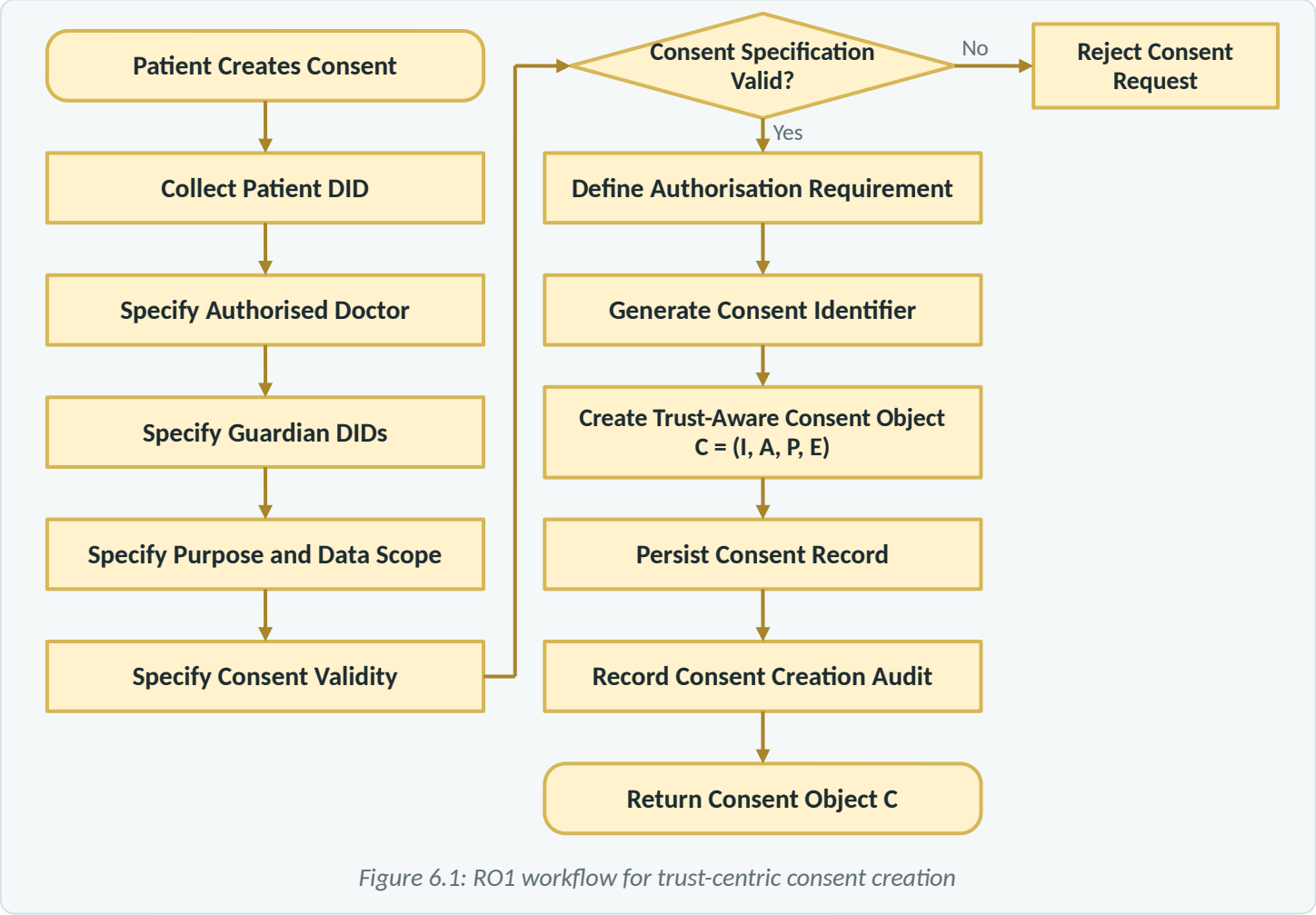


Figure 6.1: RO1 workflow for trust-centric consent creation

R02: identity is not authorisation

Section 6.2 and Algorithm 2: DID and VC checks yield $V_I(u)$, an input to R03 and R04, not an access grant



DID and VC verification

DID resolved and verified, then VC signature, issuer, subject and validity period checked



Authority match

Extracted role and authority claims must satisfy the consent's requirement A_C , otherwise INVALID



Output: $V_I(u)$

Algorithm 2 returns VALID or INVALID and records evidence; it does not grant access by itself



Prototype status

Guardian DID syntax check; EIP-712 approval signatures; W3C VC verification scheduled for CA3

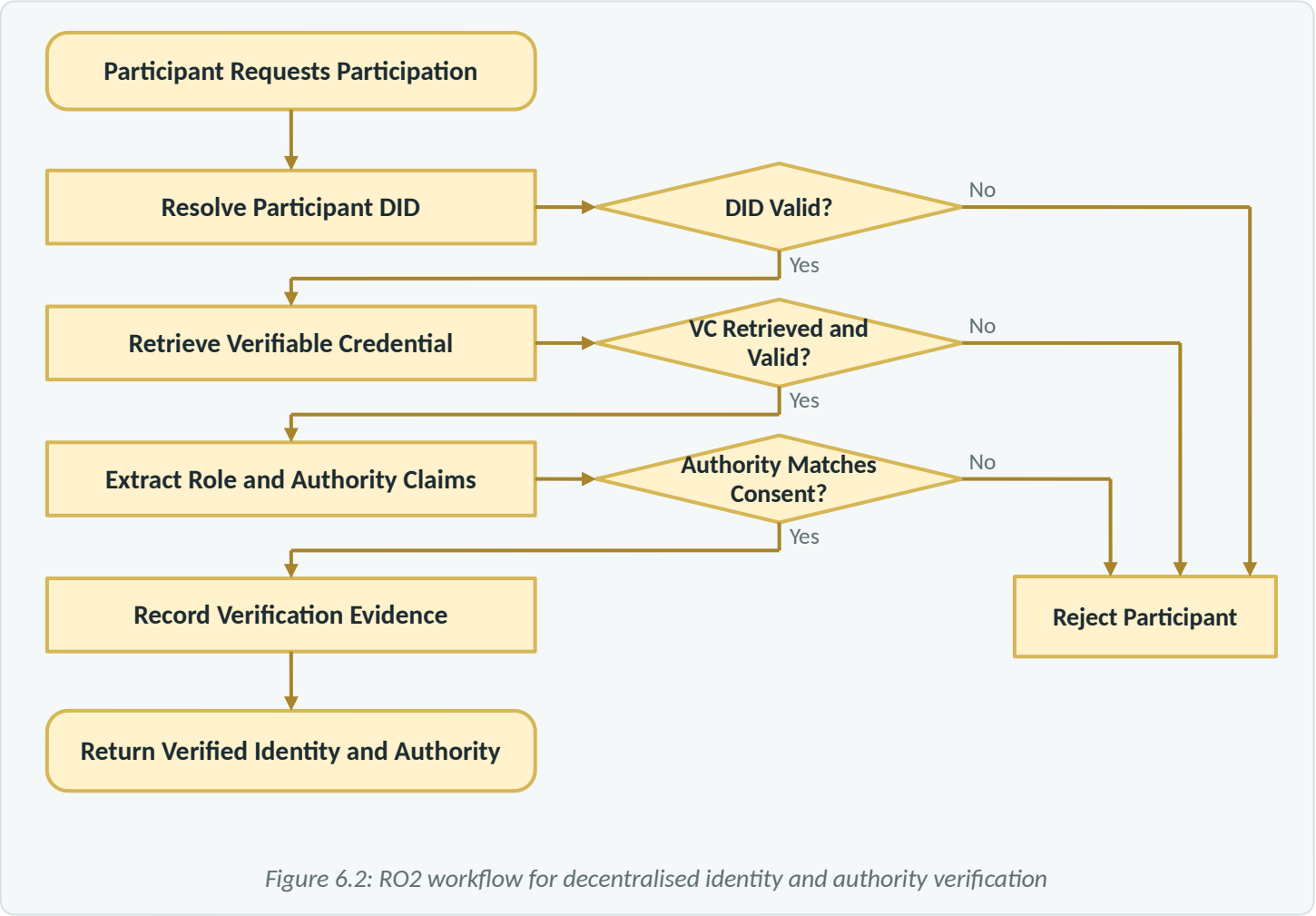


Figure 6.2: R02 workflow for decentralised identity and authority verification

RO3: no unilateral activation below the threshold

Section 6.3, Figure 6.3, Algorithm 3: only verified, eligible, non-duplicate approvals enter A_v



Threshold condition

$V_A(C) = 1$ when $|A_v| \geq N$ (Eq. 9), with $1 \leq N \leq |G|$;
below N the consent stays PENDING



Rejected approvals

Invalid identity or authority, participant not in G , or
a duplicate approval: recorded, returns DENY



Activation evidence

When $|A_v| \geq N$: authorisation activated, token
evidence generated, threshold-satisfied event
recorded



Prototype: 2-of-2 guardians

$N = |G|$ (all guardians sign); EIP-712 signatures
verified, duplicates refused, Sepolia SBT minted;
configurable k -of- n in CA3

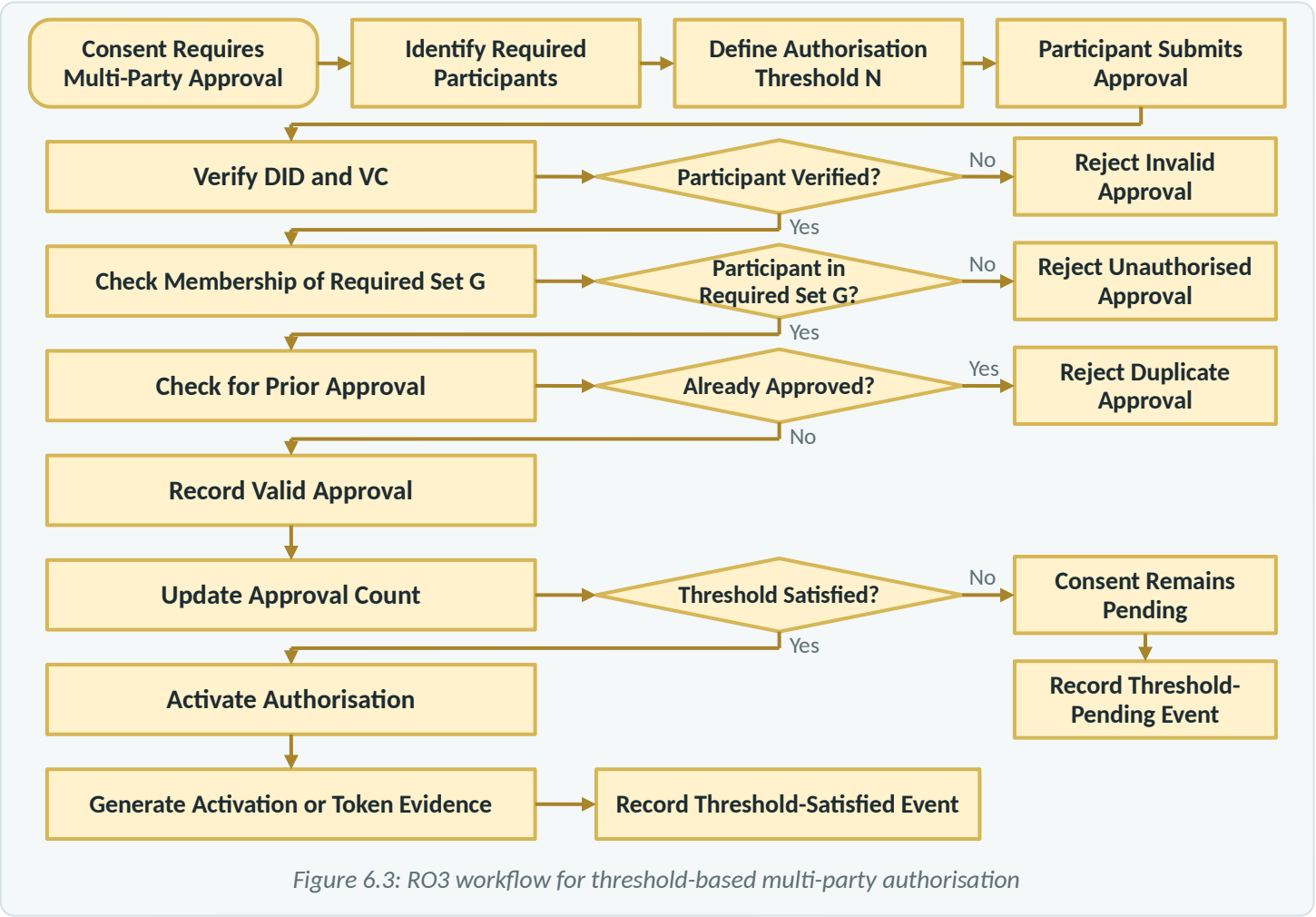


Figure 6.3: RO3 workflow for threshold-based multi-party authorisation

R04: a valid approval is not unlimited access

Section 6.4, Figure 6.4, Algorithm 4: purpose and data scope are checked before any data are released



Ordered checks

$V_1(u)$, active consent, $|A_v| \geq N$, purpose, then scope;
any failure is recorded and returns DENY



Scope containment

$S_R \subseteq S_C$ (Eq. 25), with $V_p = V_U \wedge V_S$ (Eq. 32); returned
data must also stay within S_C



Prototype: scope enforced

Only consented modules offered; service layer re-
checks $S_R \subseteq S_C$; a failure is logged as ACCESS DENIED



Prototype: purpose partly checked

Consent purpose checked against {Treatment,
Research, Emergency}; $P_R \models P_C$ comparison is CA3
work

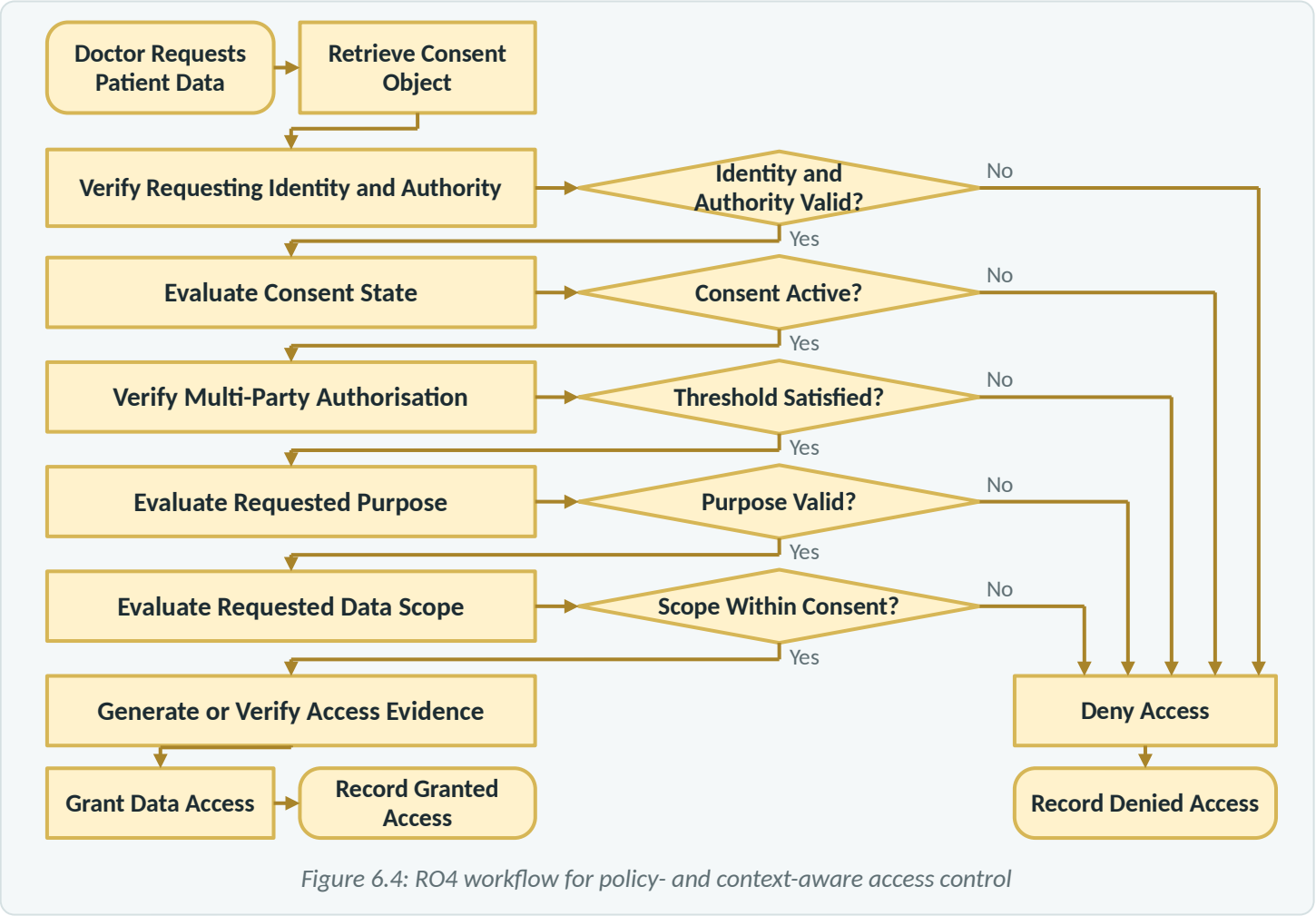


Figure 6.4: R04 workflow for policy- and context-aware access control

R05: an existing consent is not always usable

Primarily CA3. Section 6.5, Figure 6.5, Algorithm 5: $V_T(C, t)$ and $V_L(C)$ extend the decision (Eq. 24)



Two added predicates

$V_T(C, t)$: $t_s \leq t \leq t_e$ (Eq. 12); $V_L(C)$: valid state and valid transition (Eq. 15)



Prototype: state order

REVOKED, PENDING_SIGNATURE, PENDING_TOKEN, NOT_STARTED, EXPIRED, ACTIVE; only ACTIVE releases data



Prototype: revocation

Patient revocation sets REVOKED and calls revoke() on the contract; v3 enforces the interval on-chain



Remaining for CA3

Specification of legal state transitions, formal analysis of Eqs. 20–21, and adversarial evaluation

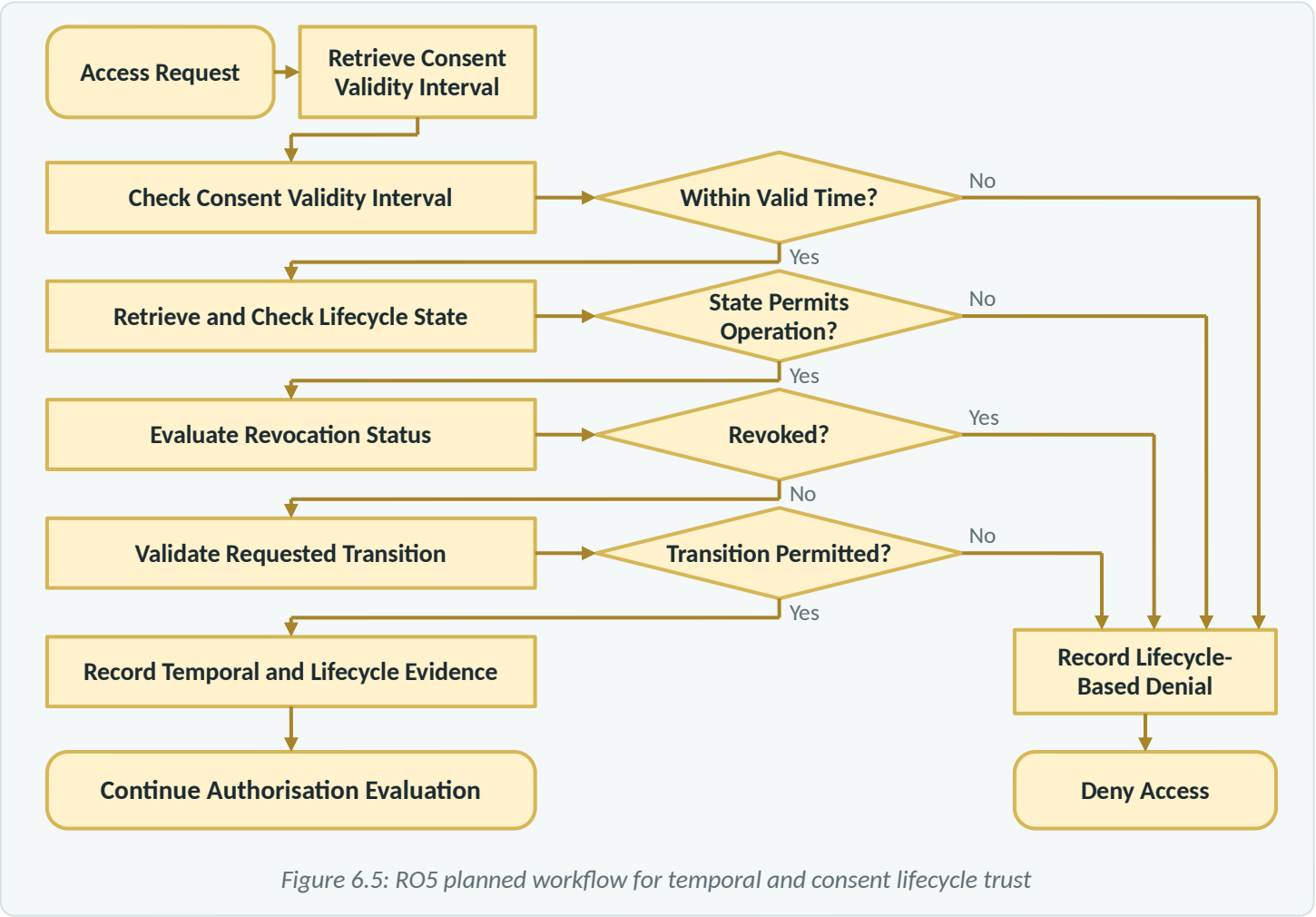


Figure 6.5: R05 planned workflow for temporal and consent lifecycle trust

R06: successful execution is not proof of security

Primarily CA3. Section 6.6, Figure 6.6, Algorithm 6: observed decisions tested against formal properties



Three scenario classes

$S = S_{\text{valid}} \cup S_{\text{negative}} \cup S_{\text{adv}}$: legitimate workflows, rule violations and bypass attempts



Six properties

$P_{\text{sound}}, P_{\text{deny}}, P_{\text{threshold}}, P_{\text{policy}}, P_{\text{scope}}, P_{\text{audit}}$; every ALLOW needs $V_I \wedge V_A \wedge V_P$ (Eq. 33)



Observed vs expected

A scenario passes only when $D_{\text{obs}}(s) = D_{\text{exp}}(s)$; each failure is traced to its condition and evidence



Implementation basis

HALAH logs consent, approval, minting, state-check and access events (Sections 7.11–7.12)

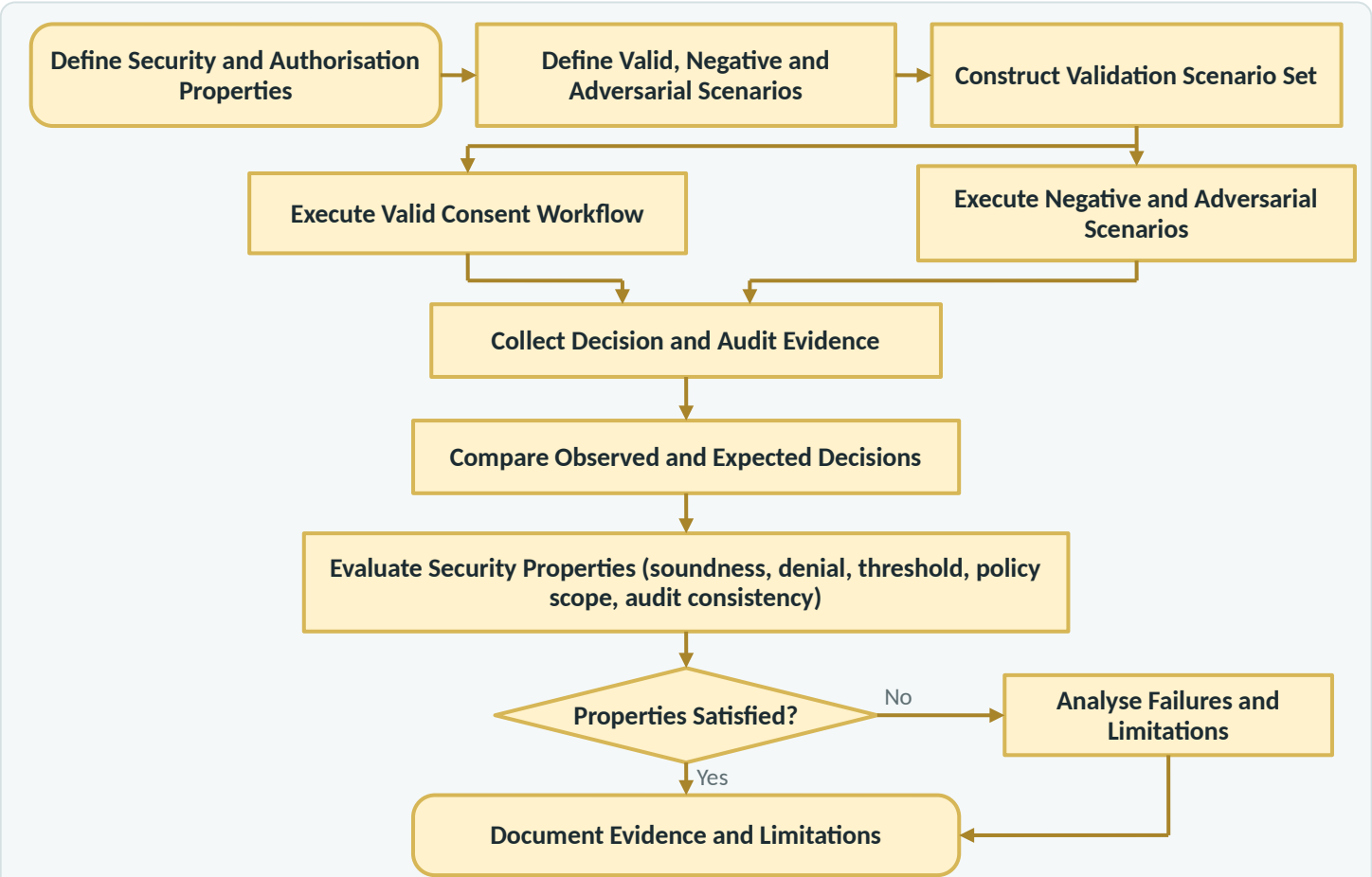


Figure 6.6: R06 planned workflow for formal security assurance and empirical validation

Six algorithms, one authorisation lifecycle

Section 6.7: Algorithms 1–4 form the current stage (CA2); Algorithms 5–6 extend them in the next stage (CA3)

Algorithm	Objective	Input	Output	Predicate
1: Trust-Aware Consent Creation	RO1: Trust-Centric Consent Model	I_p , doctor D, guardians G, P_u , S_C , T	Consent object C or rejection	Builds $C = (I, A, P, E)$ (Eq. 7)
2: DID and VC Identity and Authority Verification	RO2: Decentralised Identity and Authority Trust	Participant u, consent object C	$V_I(u)$: VALID or INVALID	$V_I(u)$ (Eq. 8)
3: Threshold-Based Multi-Party Authorisation	RO3: Trustworthy Multi-Party Authorisation	Consent C, approval a, threshold N	Authorisation: ALLOW, PENDING or DENY	$V_A(C)$: $ A_v \geq N$ (Eq. 9)
4: Policy-Aware Access Decision	RO4: Policy- and Context-Aware Access Control	Consent C, request R, participant u	Access decision: ALLOW or DENY	$V_p(C, R) = V_U \wedge V_S$ (Eq. 32)
5: Temporal and Lifecycle Validation	RO5: Temporal and Lifecycle Trust	Consent C, time t, transition q	Lifecycle validity: VALID or INVALID	$V_T(C, t)$, $V_L(C)$ (Eqs. 12, 15)
6: Formal and Empirical Authorisation Validation	RO6: Formal Security Assurance and Empirical Validation	Framework implementation F	Validation evidence and results	Six properties P; Eqs. 33–34



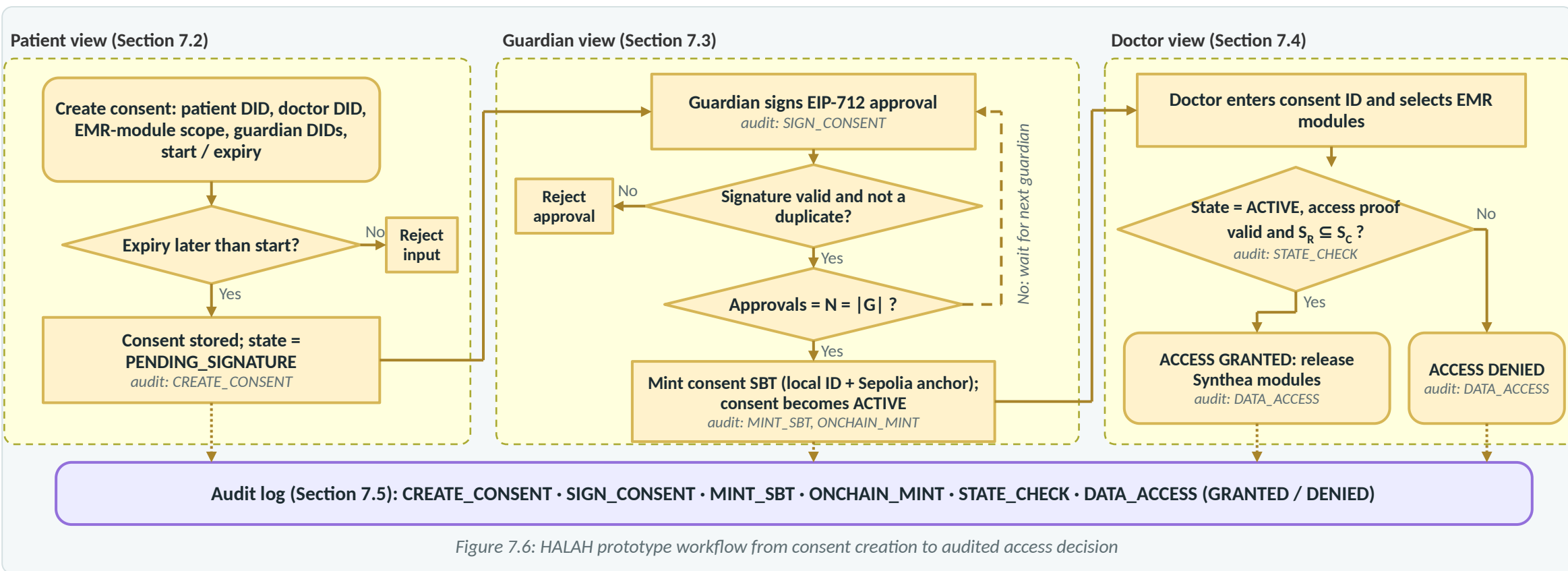
PART D • CHAPTER 7

HALAH prototype and evidence

Four role-based subsystems, the code mapping, 18 automated tests and consent tokens anchored on Sepolia

One consent lifecycle, four subsystems

A role-based consent management platform that operationalises the framework (Sections 7.1, 7.8–7.10)



Patient: create consent

Patient, doctor and guardian DIDs, module scope and start / expiry time

Guardian: approve, activate

Verifies guardian identities, records both signatures and mints the SBT

Doctor: verified access

Checks the consent is ACTIVE; access limited to the authorised modules

Auditor: trace the evidence

Rebuilds the lifecycle from event-level records and the audit ledger

Patient creates, guardians activate

Multi-party consent is built in when the consent contract is constructed (Sections 7.2–7.3)

Create Smart Consent Contract

Patient DID (Identity Pointer)

did:patient:fe621c76-a591-b7be-5668-b77f00240d

Designated Guardian DIDs (Comma Separated)

did:parent:A, did:parent:B

Authorised Doctor DID

did:doctor:001

Contract Temporal Validity

Start Time (YYYY-MM-DD HH:MM:SS)

2026-09-30 10:38:55

Expiry Time (YYYY-MM-DD HH:MM:SS)

2026-12-31 23:59:59

Jurisdiction (VL)

AU

Data Access Scope (EMR Modules)

Medication x Procedure x

Scope: Medication, Procedure

Initial Consent

Figure 7.1 (cropped): Patient subsystem – Create Smart Consent Contract

Patient: Create Smart Consent Contract

Patient DID, authorised doctor DID, EMR-module scope, guardian DIDs and start/expiry time form the consent object C

Guardian Cryptographic Approval

Enter Target Consent ID

50df30f6-6334-41e7-87b9-099d84bf6885

Found active transaction for Patient: did:patient:fe621c76-a591-b7be-5668-b77f00240d82

Select Your Guardian DID Identity

did:parent:B

Sign Consent via VC

EIP-712 signature verified (signer 0x39B12b87...). Multi-sig: 2/2

Verified 2/2

[SBT MINTED - LOCAL LEDGER]

Soulbound Token ID: SBT-LOCAL-50df30f6

Status: 2/2 guardian approval reached - Sepolia anchoring result shown below.

SBT minted

Figure 7.2 (cropped): Guardian subsystem – Guardian Cryptographic Approval

Guardian: Cryptographic Approval

Each guardian verifies their DID and signs; at 2/2 approvals the SBT is minted and the consent is fully activated

Consent is checked before data are released

Consent → Verification → AccessDecision in the doctor subsystem (Section 7.4)

Consent Information

Patient
did:patient:fe621c76-a...

Consent ID
50df30f6-6334-41e7-87...

Purpose
Treatment

Requester jurisdiction (VL check)
AU

Decision matrix - ALLOW = VI AND VA AND VP AND VT AND VL

VI	VA	VP	VT	VL	ALLOW
PASS	PASS	PASS	PASS	PASS	PASS

Consent State: ACTIVE

State: ACTIVE

Authorised Data Scope

The following EMR modules are authorised under the patient's consent:

```
[  
  0 : "Medication"  
  1 : "Procedure"  
]
```

Authorised scope

Figure 7.3 (cropped): Doctor subsystem – consent information, state and authorised scope

Consent state and authorised scope

The doctor enters the Consent ID and sees patient DID, purpose, State = ACTIVE and Scope = {Medication, Procedure}

Request Patient Data

Select Request Scope

Medication Procedure

Requested Modules: Medication, Procedure

Requested scope

Request Data Access (integrity proof - ZK placeholder)

Cryptographic Verification Successful — Access Granted.

Access granted

Authorised Medical Records

MEDICATION

	START	STOP	PATIENT	PAYER
0	2016-12-17T13:57:52Z	2016-12-30T13:57:52Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-35
1	2016-12-23T22:47:14Z	2017-12-18T22:47:14Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-35
2	2017-06-06T18:52:07Z	2017-06-24T18:52:07Z	fe621c76-a591-b7be-5668-b77f00240d82	df166300-5a78-35

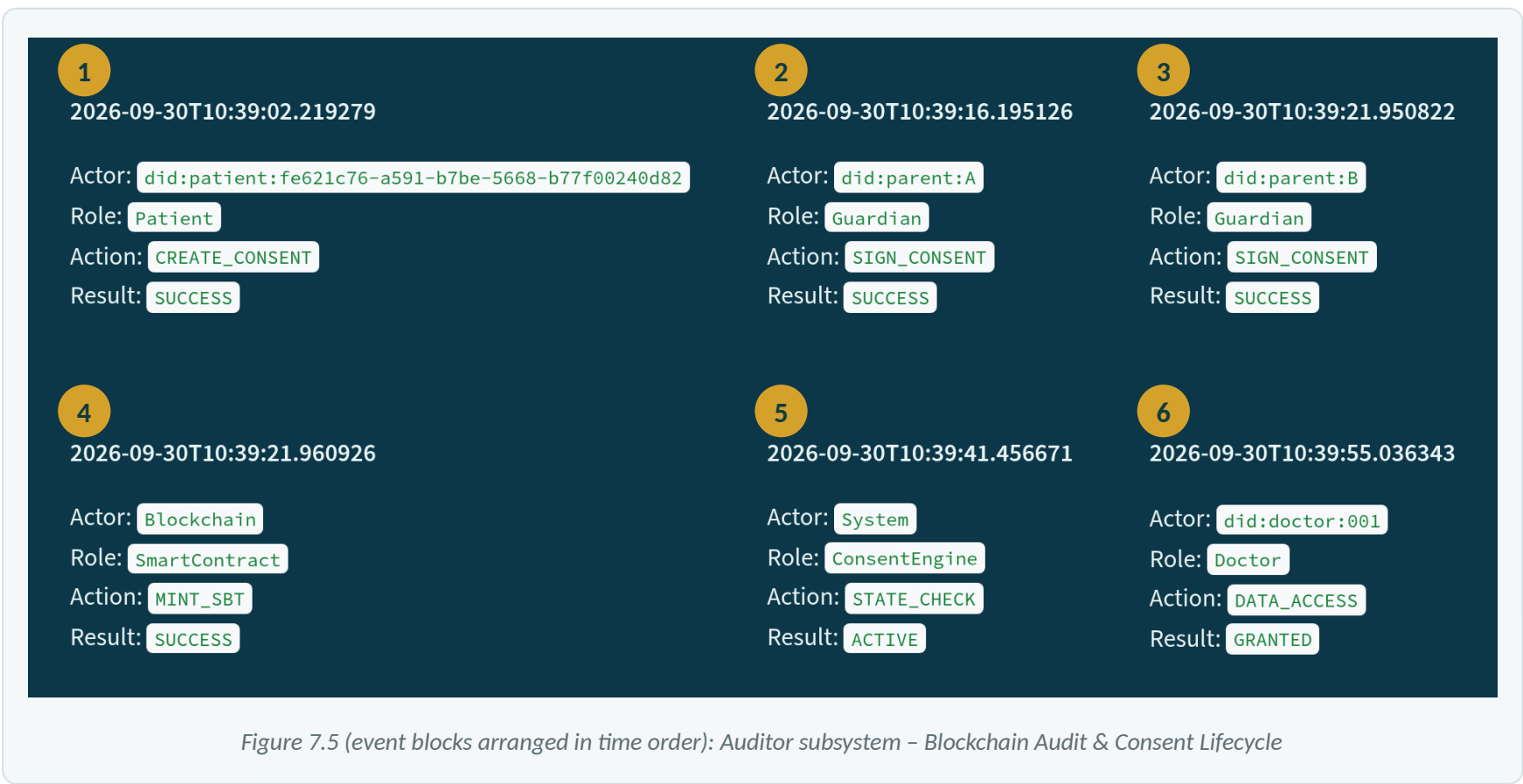
Figure 7.4 (cropped): Doctor subsystem – requested modules, access decision and records

Requested modules and access decision

Requested modules are verified, then only MEDICATION and PROCEDURE records are released; the ZK integrity proof is a v1 placeholder

Access can be traced back to its consent

Consent Lifecycle, Detailed Audit Records and Complete Blockchain Audit Ledger (Sections 7.5–7.7)



Lifecycle reconstruction

CREATE_CONSENT, SIGN_CONSENT by each guardian, MINT_SBT, STATE_CHECK, then DATA_ACCESS with GRANTED



Event-level records

Each event carries actor, role, action, result, timestamp and consent context as forensic evidence



Ledger integrity

21 total events, 3 consent events, 3 access requests; Blockchain Integrity = VERIFIED

The auditor can reconstruct who accessed the data and why: in the demo, DATA_ACCESS is GRANTED only after consent is ACTIVE

From architecture to source code

MVC layers of Chapter 5 in the HALAH prototype, repository commit 0a960ca (Section 7.10, Table 7.2)

Layer	HALAH module(s)	Responsibility
View	app.py (Patient, Guardian, Doctor, Auditor); halah_theme.py	Role-specific interaction; submits requests only
Controller	services/consent_service.py	Consent creation (Algorithm 1)
Controller	services/identity_service.py	DID check; EIP-712 approval signing and verification (Algorithms 2–3, V_I)
Controller	services/state_service.py	Consent state checks (Algorithm 5; V_A , V_T , V_L)
Controller	services/access_service.py	Scope check, release gate, decision matrix (Algorithm 4, V_P)
Controller	services/blockchain_service.py; services/anchor_service.py	SBT minting, revocation and on-chain anchoring (evidence E)
Model	models/consent.py; models/access.py; database/ (SQLite)	$C = (I, A, P, T, L, E)$ and request R; consent, approval and audit state
Protected resource	data/synthea/*.csv via database/repository.py	Synthetic EMR modules, released only after authorisation
Smart contract	contracts/ConsentSBTV3.sol (v2 for the Table 7.4 evidence)	Soulbound consent token; on-chain validity; ERC-5484 burn

18 automated tests, none failed

pytest 9.1.1, Python 3.11, run on 28 September 2026 (Section 7.11, Table 7.3)

16

tests passed

2

skipped
ZK circuit not built

0

failed

ID	Scenario	Predicate	Result
T1	EIP-712 guardian approval	V_I	Pass
T2	Decision matrix	V_I-V_L	Pass
T3	End-to-end lifecycle, chain mocked	V_A, V_L	Pass
T4	Revocation state	V_L	Pass
T5	v3 contract routing	V_T	Pass
T6	Persistence (3 tests)	E	Pass
T7	Audit honesty (2 tests)	E	Pass
T8	Configuration & honesty (6 tests)	-	Pass
T9	Groth16 zero-knowledge (2 tests)	V_T	Skipped

Functional unit and integration tests with the blockchain mocked; not yet the full valid, negative and adversarial scenario set of Algorithm 6

Consent tokens anchored on Sepolia

Four consent SBTs minted by ConsentSBTv2 on the Ethereum Sepolia testnet (Section 7.12, Table 7.4)



Ethereum Sepolia testnet

Chain ID 11155111

ConsentSBTv2 contract

0xb0dA0440Abd6bd74bE0aebE226D593492124A6e7

Token	Block	Transaction hash (shortened)
#1	11750525	0x5bfb45ee...c0de105367
#2	11750632	0x1b964596...e56fc522907
#3	11750702	0x6812ab16...aabef251121
#4	11750722	0xa4c4156b...eff497e014a

Full hashes: Table 7.4 in the report.

Anchored activation

When the threshold is reached, the consent is anchored by minting a non-transferable consent token

DID-to-address binding

The holder of token #4 equals the address derived from the patient DID 'did:patient:demo'

v2 deployed, v3 current

Evidence recorded with ConsentSBTv2; ConsentSBTv3 is the current source and is exercised by test T5

The tokens show on-chain anchoring and the DID-to-address binding; Sepolia is a public testnet, not a production network (Section 7.13)

Implementation status and limitations

Figures 7.1–7.5 come from the first version; the current version is v1.1 (Section 7.13)

v1.1 records EIP-712 guardian approvals, reports on-chain anchoring per event and labels the data-access proof a placeholder unless the ZK circuit is built.



Identity evidence

Guardian keys derived from the DID for demonstration; DID check is syntactic; no W3C VC yet (CA3)



Fixed threshold

$N = |G|$, so all designated guardians must approve; configurable k-of-n thresholds are not yet supported



Purpose and release gate

Fixed purpose list; per-request binding in CA3; release gated by state, proof and scope, not the full decision matrix



Synthetic data, testnet

Healthcare data are synthetic (Synthea); the blockchain is a public testnet, not a production network



Zero-knowledge proof

Groth16 circuit covers consent validity only; development-only trusted setup; not built for the test run (T9 skipped)



Functional evaluation

18 automated tests to date; performance and adversarial measurements are CA3 work



E

PART E • CHAPTERS 8–10

Progress and research plan

Where each objective stands, the publication plan and the next-stage (CA3) work on RO5 and RO6

R01–R04 completed at prototype level; R05–R06 partial

Chapter 8: the status of each research objective and the evidence behind it

RO1	Trust-Centric Consent Model	Completed	Consent as an evaluable object $C = (I, A, P, E)$ (Eq. 7); HALAH uses $C = (I, A, P, T, L, E)$
RO2	Decentralised Identity and Authority	Completed (prototype; W3C VC in CA3)	Identity $\neq$ authorisation (Eq. 1); wrong guardian, consent ID or missing signature rejected (T1)
RO3	Trustworthy Multi-Party Authorisation	Completed	$ A_v \geq N$ (Eq. 9); 1/2 approvals: consent PENDING_SIGNATURE; 2/2 plus SBT mint: ACTIVE (T3)
RO4	Policy-Aware Access Control	Completed (prototype level)	$S_R \subseteq S_C$ enforced in the service layer (Eq. 25); out-of-scope request: ACCESS DENIED, logged
RO5	Temporal and Lifecycle Trust	Partially completed (prototype)	First version (expiry and revocation) operational; formal lifecycle analysis in CA3
RO6	Security Assurance and Validation	Partially completed (SRQ1–SRQ4)	16 automated tests passed (Table 7.3); formal properties and adversarial tests in CA3

Publication plan: three research outputs

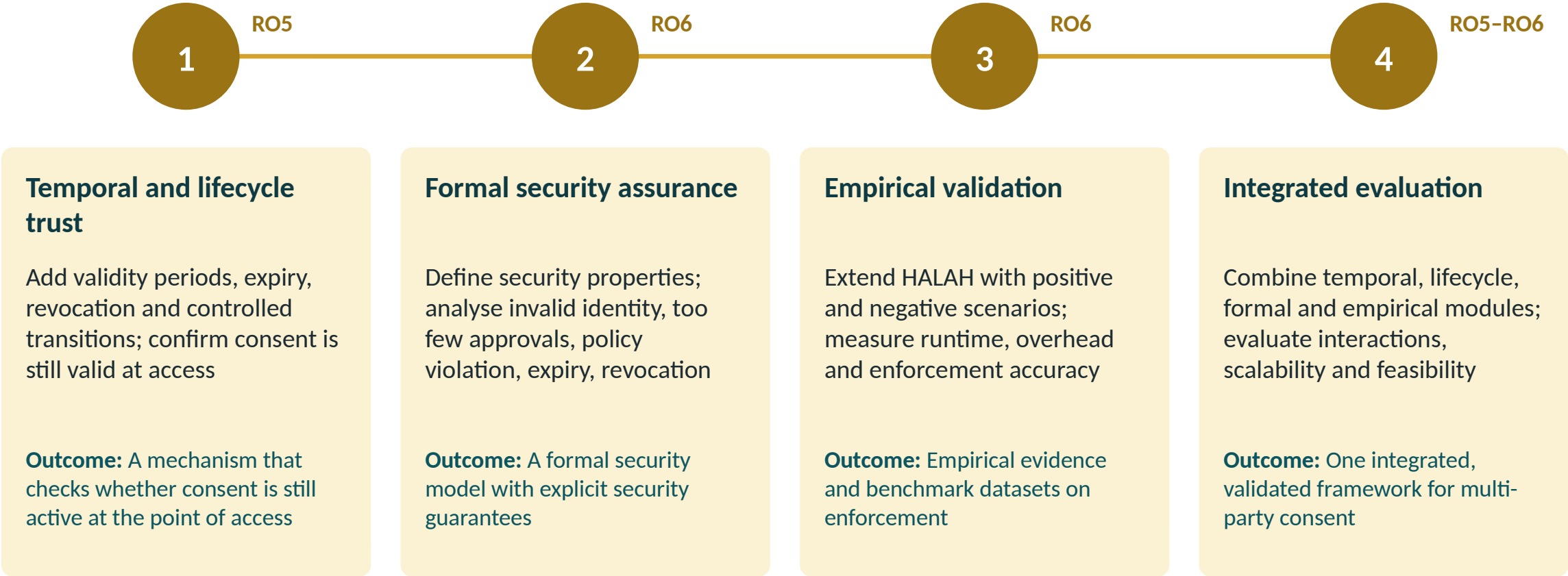
Table 9.1: the first paper is drafted, with submission to Computers & Security planned for November 2026

Research output	Target venue	Status
Trust-Centric Consent Framework: model, multi-party policies	Computers & Security (Elsevier)	Draft complete; submission planned November 2026
HALAH Prototype & Validation: implementation and evaluation	Systems / Security Conference	In progress
Formal Security & Lifecycle Analysis: temporal constraints	Specialised Workshop / Journal	Planned

Next-stage plan: four research focuses

Section 10.2, Table 10.1: whether trust can be maintained over time, formally justified and demonstrated

Next stage (CA3): RO5 and RO6



From recorded consent to an evaluated decision

Contributions of the current stage (Chapters 1, 5, 10 and Section 2.6) and the path to CA3

No single mechanism makes access trustworthy. The contribution is one explainable decision built from independently verifiable conditions.



Consent as an evaluable object

$C = (I, A, P, E)$
 $\text{Decision}(C, R) = \text{ALLOW}$
 $\Leftrightarrow V_I \wedge V_A \wedge V_P$
Consent is evaluated, not just stored as a record

Evidence: Eq. (6), Eq. (7);
Chapter 5



MVC research architecture

View submits claims,
Controller evaluates predicates, Model holds trust state; data only via the Controller

Evidence: Chapter 5; Table 7.2



HALAH prototype

Patient, guardian, doctor and auditor subsystems; EIP-712 guardian approvals; consent SBTs on Ethereum Sepolia

Evidence: Chapter 7; Tables 7.1 and 7.4



Evidence and path to CA3

Initial evidence: 16 tests passed, SRQ1–SRQ4; CA3 adds lifecycle trust, formal assurance, empirical validation

Evidence: Table 7.3: 16 passed, 2 skipped, 0 failed

Thank you

Questions and feedback

Yasir Dhaifallah O Alyoubi

YasirDhaifallahO.Alyoubi@student.uts.edu.au

Principal Supervisor: Professor Farookh Hussain · Co-Supervisor: Dr Firas Al-Doghman

